



A Report on

SQL INJECTION AND VULNERABILITIES

Submitted in partial fulfillment of the requirement for the course

CS872 – COMPREHENSION

SUBMITTED BY

T.VIJAY KUMAR

1860416

Department of Computer Science and Engineering

School of Engineering and Technology,

CHRIST(Deemed to be University),

Kumbalgodu, Bengaluru - 74.

May 2022



A Report on

SQL INJECTION AND VULNERABILITIES

Submitted in partial fulfillment of the requirement for the course

CS872 – COMPREHENSION

SUBMITTED BY

T.VIJAY KUMAR

1860416

Dr. Balachandran K

Faculty-In-Charge

Examiner

Head of Department

Department of Computer Science and Engineering

School of Engineering and Technology,

CHRIST(Deemed to be University),

Kumbalgodu, Bangalore - 74.

May 2022



CHRIST
(DEEMED TO BE UNIVERSITY)
BANGALORE • INDIA

School of Engineering and Technology

Department of Computer Science and Engineering

CERTIFICATE

This is to certify that **T.VIJAY KUMAR** has successfully completed the comprehension work entitled “**SQL INJECTION AND VULNERABILITIES**” in partial fulfillment for the award of **Bachelor of Technology in Computer Science and Engineering** during the year **2021-2022**.

Faculty-In-Charge

Dr Balachandran K
Head of the Department

Dr Iven Jose
Dean

Acknowledgement

I would like to thank **Dr Fr Abraham V M**, Vice Chancellor, CHRIST (Deemed to be University), **Dr Fr Joseph CC**, Pro Vice Chancellor, **Dr Fr Benny Thomas**, Director, School of Engineering and Technology and **Dr Iven Jose**, Dean for their kind patronage.

I would also like to express sincere gratitude and appreciation to **Dr Balachandran K**, Head of the Department, Department of Computer Science and Engineering for giving me this opportunity to take up this work.

Abstract

The report presents a methodology for SQL INJECTION, SQL injection, also known as SQLI, is a common attack vector that uses malicious SQL code for back end database manipulation to access information that was not intended to be displayed. This information may include any number of items, including sensitive company data, user lists or private customer details.

We all know how often nowadays we see cases of data theft and how Hackers or attackers exploit the vulnerabilities in DBMS systems in order to steal confidential information.

SQL Injection is one such technique which the attackers use in order to gain some information about the DBMS system. Using SQL injection, a hacker will try to enter a specifically crafted SQL commands into a form field instead of the expected information. The intent is to secure a response from the database that will help the hacker understand the database construction, such as table names. They are a type of vulnerability in the code of websites and web apps that allows attackers to hijack back-end processes and access, extract, and delete confidential information from your databases. Attackers use malicious SQL statements in the input box, and in response, the database presents sensitive information.

Keywords: DBMS,SQLI

Contents

CERTIFICATE	i
ACKNOWLEDGEMENT	ii
ABSTRACT	iii
1 INTRODUCTION	1
1.1 Problem Identification	2
1.2 Need for the study	2
1.3 Problem Statement & Objectives	2
2 ARCHITECTURE	4
3 LITERATURE SURVEY AND REVIEW	6
3.1 LITERATURE REVIEW AND SEGREGATION	6
3.2 EXISTING SYSTEM	
3.3 PROPOSED SYSTEM	6
4 DESCRIPTION	9
4.1 Testing, Analysis & Design	9
5 APPLICATIONS	13
6 ADVANTAGES AND DISADVANTAGES	14
6.1 ADVANTAGES	14
6.2 DISADVANTAGES OF EXISTING SYSTEM	14
7 RESULTS AN DISCUSSIONS	16
7.1 Conclusions	16
7.2 Scope for Future Work	17
Bibliography	18

Chapter 1

INTRODUCTION

SQL injection, also known as SQLi, is a common attack vector that uses malicious SQL code for backend database manipulation to access information that was not intended to be displayed. This information may include any number of items, including sensitive company data, user lists or private customer details.

The impact SQL injection can have on a business is far-reaching. A successful attack may result in the unauthorized viewing of user lists, the deletion of entire tables and, in certain cases, the attacker gaining administrative rights to a database, all of which are highly detrimental to a business.

When calculating the potential cost of an SQLi, it's important to consider the loss of customer trust should personal information such as phone numbers, addresses, and credit card details be stolen. While this vector can be used to attack any SQL database, websites are the most frequent targets. As we all know how often nowadays we see cases of data theft and how Hackers or attackers exploit the vulnerabilities in DBMS systems in order to steal confidential information. SQL Injection is one such technique which the attackers use in order to gain some information about the DBMS system. Using SQL injection, a hacker will try to enter a specifically crafted SQL commands into a form field instead of the expected information. The intent is to secure a response from the database that will help the hacker understand the database construction, such as table names. They are a type of vulnerability in the code of websites and web apps that allows attackers to hijack back-end processes and access, extract, and delete confidential information from your databases. Attackers use malicious SQL statements in the input box, and in response, the database presents sensitive information.

1.1 Problem Identification

A SQL Injection attack consists of insertion or “injection” of a SQL query via the input data from the client to the application. A successful SQL injection exploit can read sensitive data from the database, modify database data (Insert/Update/Delete), execute administration operations on the database (such as shutdown the DBMS), recover the content of a given file present on the DBMS file system and in some cases issue commands to the operating system. SQL injection attacks are a type of injection attack, in which SQL commands are injected into data-plane input in order to affect the execution of predefined SQL commands. SQL injection attacks allow attackers to spoof identity, tamper with existing data, cause repudiation issues such as voiding transactions or changing balances, allow the complete disclosure of all data on the system, destroy the data or make it otherwise unavailable, and become administrators of the database server.

- SQL Injection is very common with PHP and ASP applications due to the prevalence of older functional interfaces. Due to the nature of programmatic interfaces available, J2EE and ASP.NET applications are less likely to have easily exploited SQL injections.
- The severity of SQL Injection attacks is limited by the attacker’s skill and imagination, and to a lesser extent, defense in depth countermeasures, such as low privilege connections to the database server and so on. In general, consider SQL Injection a high impact severity. SQL injection attack occurs when:
 1. An unintended data enters a program from an untrusted source.
 2. The data is used to dynamically construct a SQL query

main consequences are:

- **Confidentiality:** Since SQL databases generally hold sensitive data, loss of confidentiality is a frequent problem with SQL Injection vulnerabilities.
- **Authentication:** If poor SQL commands are used to check user names and passwords, it may be possible to connect to a system as another user with no previous knowledge of the password.

- **Authorization:** If authorization information is held in a SQL database, it may be possible to change this information through the successful exploitation of a SQL Injection vulnerability.

1.2 Need for the study

SQL Injection is very common with PHP and ASP applications due to the prevalence of older functional interfaces. Due to the nature of programmatic interfaces available, J2EE and ASP.NET applications are less likely to have easily exploited SQL injections. The severity of SQL Injection attacks is limited by the attacker's skill and imagination, and to a lesser extent, defense in depth countermeasures, such as low privilege connections to the database server and so on. In general, consider SQL Injection a high impact severity. SQL injection attack occurs when:

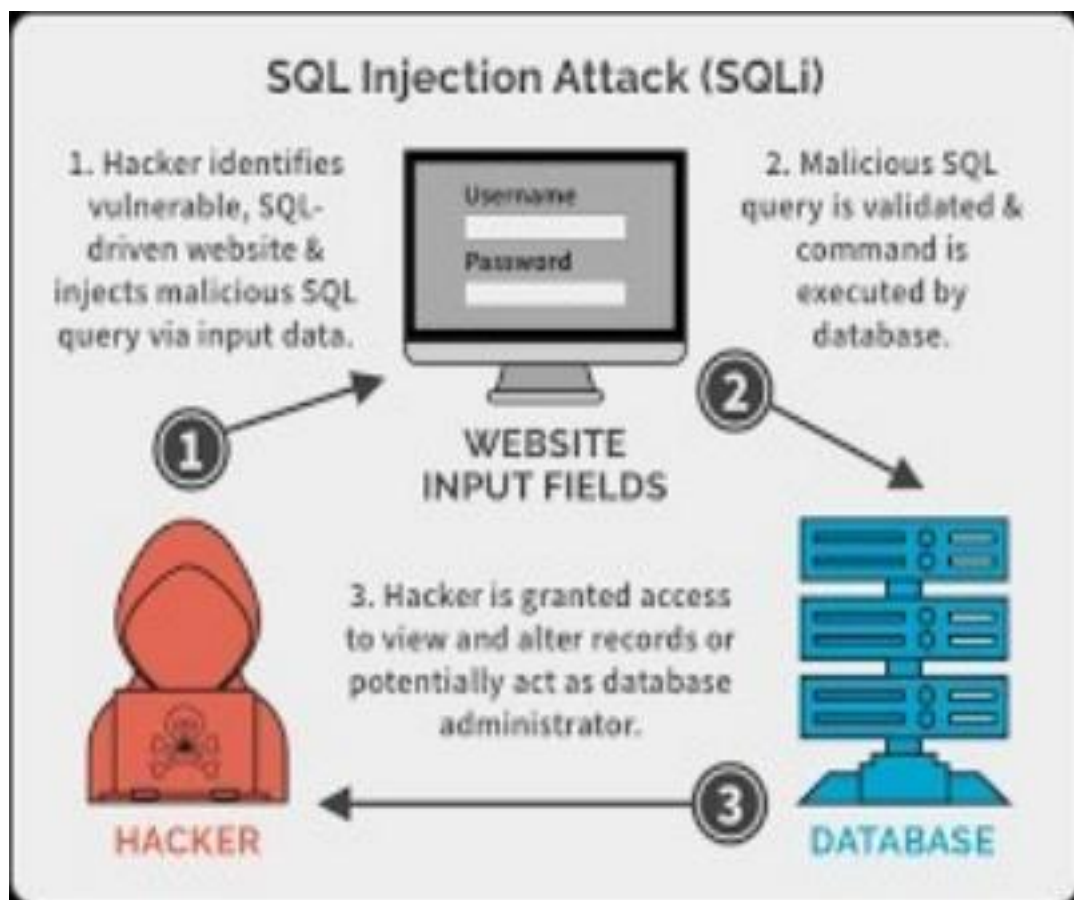
1.3 Problem Statement & Objectives

Objectives of the project:

- To understand the basics of security assessment.
- To understand back end database manipulation in order to access information that was not intended to be displayed.
- To understand and implement the process of bypassing the authentication process.
- To implement various methods for gaining root access to the system itself.
- To understand and implement various prevention techniques against Sqli.

Chapter 2

ARCHITECTURE



SQL Injection Attack

1.Initial phase(setup):In this phase we basically setup our virtual machines(attacker and victim machines).This is the first step of the project where we have to setup machines i.e, Oracle VM Virtual Box with Kali Linux installed.

2.Exploitation of vulnerabilities:In this phase, we look for a vulnerable input in a web application or web page.

- When an application or web page contains a SQL injection vulnerability, it uses user input in the form of an SQL query directly.
- SQL statements are used to retrieve and update data in the database. Attackers use malicious SQL statements in the input box, and in response, the database presents sensitive information.

3.Sql Injection :This consists of insertion or “injection” of a SQL query via the input data from the client to the application. A successful SQL injection exploit can read sensitive data from the database, modify database data (Insert/Update/Delete), execute administration operations on the database (such as shutdown the DBMS), recover the content of a given file present on the DBMS file system and in some cases issue commands to the operating system.In this step, When an application or web page contains a SQL injection vulnerability, it uses user input in the form of an SQL query directly.Here,we use SQL statements are used to retrieve and update data in the database.Attackers can use SQL Injections to find the credentials of other users in the database.

Chapter 3

LITERATURE SURVEY AND REVIEW

3.1 LITERATURE SURVEY

Intuitively, an SQL Injection Attack (SQLIA) occurs when an attacker changes the intended effect of an SQL query by inserting new SQL keywords or operators into the query. This informal definition is intended to include all of the variants of SQLIAs reported in literature. The cause of SQL injection vulnerabilities is relatively simple and well understood: insufficient validation of user input. To address this problem, developers have proposed a range of coding guidelines that promote defensive coding practices, such as encoding user input and validation. A rigorous and systematic application of these techniques is an effective solution for preventing SQL injection vulnerabilities. However, in practice, the application of such techniques is human-based and, thus, prone to errors. Furthermore, fixing legacy code-bases that might contain SQL injection vulnerabilities can be an extremely labor-intensive task. Although recently there has been a great deal of attention to the problem of SQL injection vulnerabilities, many proposed solutions fail to address the full scope of the problem.

There are many types of SQLIAs and countless variations on these basic types. Researchers and practitioners are often unaware of the myriad of different techniques that can be used to perform SQLIAs. Therefore, most of the solutions proposed detect or prevent only a subset of the possible SQLIAs. To address this problem, we present a comprehensive survey of SQL injection attacks known to date.

To compile the survey, we used information gathered from various sources, such as papers, Web sites, mailing lists, and experts in the area. For each attack type considered, we give a characterization of the attack, illustrate its effect, and provide examples of how that type of attack could be performed. This set of attack types is then used to evaluate state of the art detection and prevention techniques and compare their strengths and weaknesses

3.2 EXISTING SYSTEM

The system is decentralized, creating transparency, immutable and secure. some Existing system is centralized. There may be not full secure or immutable . Existing system has several disadvantages such as

1. Redundancy in stored data
2. Lack of security
3. Data is inconsistent
4. high maintenance

3.3 PROPOSED SYSTEM

The proposed system is developed based on A SQL Injection attack consists of insertion or “injection” of a SQL query via the input data from the client to the application. A successful SQL injection exploit can read sensitive data from the database, modify database data (Insert/Update/Delete), execute administration operations on the database (such as shutdown the DBMS), recover the content of a given file present on the DBMS file system and in some cases issue commands to the operating system. SQL injection attacks are a type of injection attack, in which SQL commands are injected into data-plane input in order to affect the execution of predefined SQL commands. SQL injection attacks allow attackers to spoof identity, tamper with existing data, cause repudiation issues such as voiding transactions or changing balances, allow the complete disclosure of all data on the system, destroy the data or make it otherwise unavailable, and become administrators of the database server

Chapter 4

DESCRIPTION

4.1 Testing, Analysis & Design

1. Testing

The aim of testing is to find mistakes. Testing is the method of attempting to find any possible flaws in a project. It allows you to test the functionality of individual parts, sub assemblies, assemblies, and/or a finished product. It is the process of testing software to ensure that it meets its specifications and meets user expectations, and that it does not fail in an inappropriate way. There are several different types of tests. Each test form is designed to address a particular testing need. From our initial tests we were able to successfully get :

- Log in to an app or a website front end without a password.
- Access,extract and delete stored data from secured databases.

From the tests we got to know when an application or web page contains a SQL injection vulnerability, it uses user input in the form of an SQL query directly.Here,we use SQL statements are used to retrieve and update data in the database.Attackers can use SQL Injections to find the credentials of other users in the database.

2. Analysis

From the analysis we get to know when an application or web page contains a SQL injection vulnerability, it uses user input in the form of an SQL query directly.Here,we use SQL statements are used to retrieve and update data in the database.Attackers can use SQL Injections to find the credentials of other users in the database. It consisted of insertion or “injection” of a SQL query via the input data from the client to the application. A successful SQL injection exploit can read sensitive data from the database, modify database data (Insert/Update/Delete), execute administration operations on the database (such as shutdown the DBMS), recover the content of a given file present on the

DBMS file system and in some cases issue commands to the operating system.

3. Design

There are basically 4 modules which are implemented in our final project which are namely:

1.Initial phase(setup):In this phase we basically setup our virtual machines(attacker and victim machines).This is the first step of the project where we have to setup machines i.e, Oracle VM Virtual Box with Kali Linux installed.

2.Exploitation of vulnerabilities:In this phase, we look for a vulnerable input in a web application or web page.

When an application or web page contains a SQL injection vulnerability, it uses user input in the form of an SQL query directly.SQL statements are used to retrieve and update data in the database. Attackers use malicious SQL statements in the input box, and in response, the database presents sensitive information.

3.SQL Injection:This consists of insertion or “injection” of a SQL query via the input data from the client to the application. A successful SQL injection exploit can read sensitive data from the database, modify database data (Insert/Update/Delete), execute administration operations on the database (such as shutdown the DBMS), recover the content of a given file present on the DBMS file system and in some cases issue commands to the operating system.In this step, When an application or web page contains a SQL injection vulnerability, it uses user input in the form of an SQL query directly.Here,we use SQL statements are used to retrieve and update data in the database.Attackers can use SQL Injections to find the credentials of other users in the database.

When SQLi attacks are successful, attackers can:

- Log in to an app or a website front end without a password.
- Access, extract and delete stored data from secured databases.

Create their own databases records or modify existing records, opening the door for further attacks.

Threat Modeling

- SQL injection attacks allow attackers to spoof identity, tamper with existing data, cause repudiation issues such as voiding transactions or changing balances, allow the complete disclosure of all data on the system, destroy the data or make it otherwise unavailable, and become administrators of the database server.
- SQL Injection is very common with PHP and ASP applications due to the prevalence of older functional interfaces. Due to the nature of programmatic interfaces available, J2EE and ASP.NET applications are less likely to have easily exploited SQL injections.
- The severity of SQL Injection attacks is limited by the attacker's skill and imagination, and to a lesser extent, defense in depth countermeasures, such as low privilege connections to the database server and so on. In general, consider SQL Injection a high impact severity.

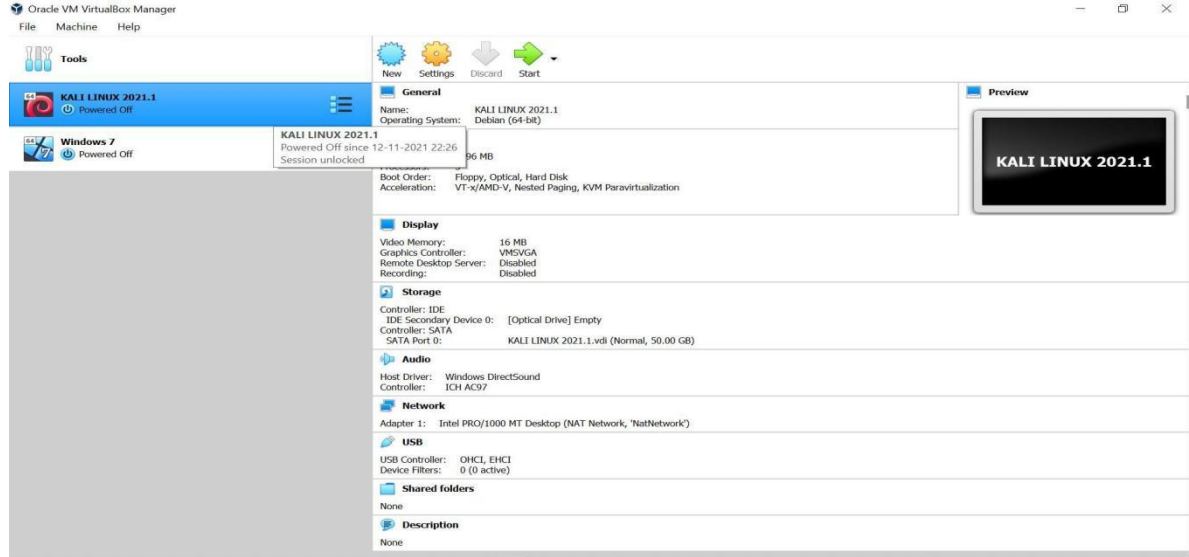


FIGURE 4.1: Kali Linux

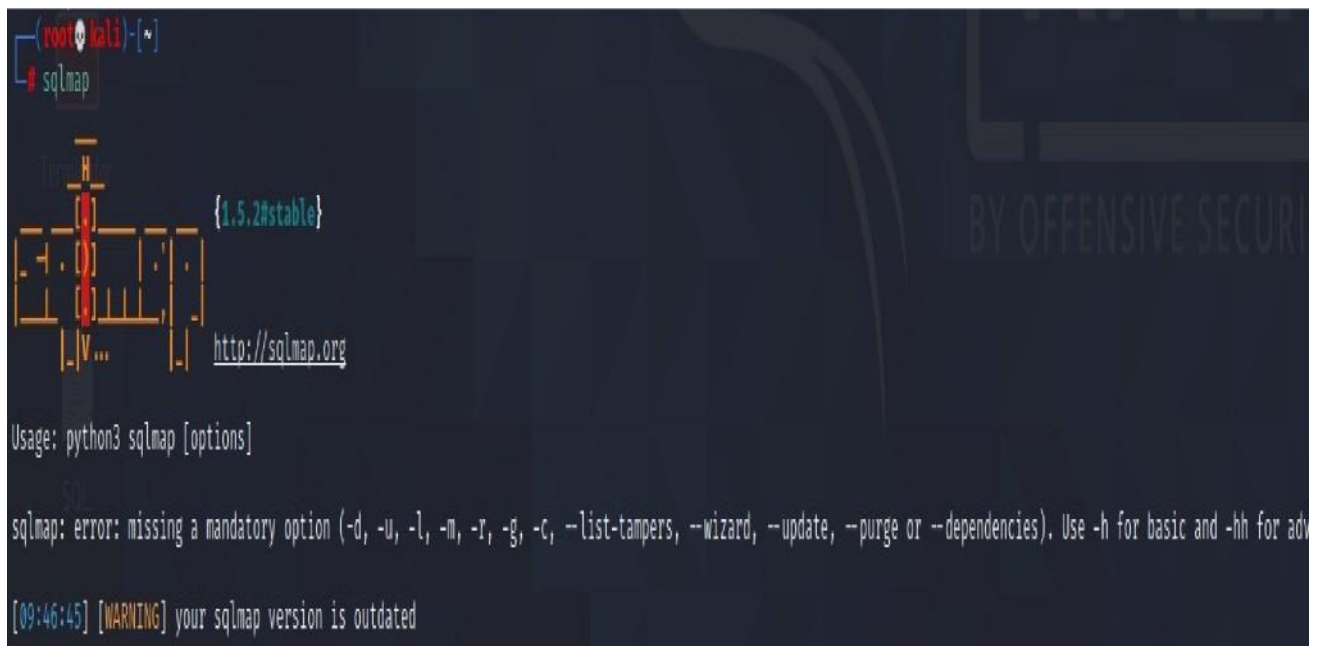


FIGURE 4.2: SQL map

Chapter 5

APPLICATIONS

- (a) Used as a security assessment Tool
- (b) Vulnerability applications
- (c) Useful tool for Penetration Testing.
- (d) VAPT Analysis

Chapter 6

ADVANTAGES AND DISADVANTAGES

6.1 ADVANTAGES

When it comes to advantages, they are unlimited and there are much more possibilities that no other ecosystem offers. SQL injection attack is a major threat to web application security. It has been rated as one of the most dangerous vulnerabilities for a web-based application. Based on the Open Web Application Security Project (OWASP), it is measured as one of the top ten. Many types of research have been made to face this attack either by preventing the threat or by at least detecting it. We aim in this paper to give an overview of the SQL injection (SQLI) attack and classify these attacks and prevention and detection tools.

SQL lets you select and output data from the database. An SQL Injection vulnerability could allow the attacker to gain complete access to all data in a database server. SQL also lets you alter data in a database and add new data.

6.2 DISADVANTAGES OF EXISTING SYSTEM

Although SQL Injection has many advantages, still there are a few disadvantages. SQL has a difficult interface that makes few users uncomfortable while dealing with the database. Some versions are costly and hence, programmers cannot access it. Due to hidden business rules, complete control is not given to the database.

Depending on just how in-depth your security settings on your system are, SQL Injection would allow someone to take complete control of your network given enough time & access. SQL injection attacks pose a serious security threat to organizations. A successful SQL injection attack can result in confidential data being deleted, lost or stolen; websites being defaced; unauthorized access to systems or accounts and, ultimately, compromise of individual machines or entire networks.

Chapter 7

RESULTS AN DISCUSSIONS

7.1 Conclusions

Through this comprehension review I got to know that despite the fact that technology is important in the information security framework, some detection technology alone was not enough to keep an organization secure from data breaches. SQL injection is one of the more common and more effective forms of attack on a system. Controlling the malicious SQL code/script on the web application and maintaining the end privacy is still a key challenge for the web developer nowadays. Finally I want to add that the work which was put into building this report is helping me to get a better understanding on the concept of SQLI attacks and its vulnerabilities .Overall this was a very good learning experience.

7.2 Scope for Future Work

This model can be used in VAPT(Vulnerability Analysis and Penetration Testing).Vulnerability Assessment and Penetration Testing (VAPT) are two types of vulnerability testing. The tests have different strengths and are often combined to achieve a more complete vulnerability analysis. In short, Penetration Testing and Vulnerability Assessments perform two different tasks, usually with different results, within the same area of focus.Vulnerability assessment tools discover which vulnerabilities are present, but they do not differentiate between flaws that can be exploited to cause damage and those that cannot.

Vulnerability scanners alert companies to the preexisting flaws in their code and where they are located. Penetration tests attempt to exploit the vulnerabilities in a system to determine whether unauthorized access or other malicious activity is possible and identify which flaws pose a threat to the application. Penetration tests find exploitable flaws and measure the severity of each.

A penetration test is meant to show how damaging a flaw could be in a real attack rather than find every flaw in a system. Together, penetration testing and vulnerability assessment tools provide a detailed picture of the flaws that exist in an application and the risks associated with those flaws.From the initial results of our project we can say that SQL injection technique can be used by pen testers for checking any vulnerabilities in a particular web application.By using SQL injection pen testers can check the login module of the application and see if it is vulnerable to such attacks or not.If the web application is vulnerable then the intruder can check table names,no of columns,rows etc from the back end .basically all the information which should not be disclosed to the outer world on a free basis.

Bibliography :

- 1.<https://www.jigsawacademy.com/blogs/cyber-security/sql-injection-attack/>
- 2.A Classification of SQL Injection Attacks and Countermeasures William G.J. Halfond, Jeremy Viegas, and Alessandro Orso.<https://www.cc.gatech.edu/fac/Alex.Orso/papers/halfond.viegas.orso.ISSSE06.pdf>
- 3.N. Antunes and M. Vieira, "Defending against Web Application Vulnerabilities", Computer Journal, vol. 45, no. 2, pp. 66-72, Feb 2012
- 4.Sql Injection Attacks and defense by Justin Clarke
- 5.A SURVEY ON SQL INJECTION: VULNERABILITIES, ATTACKS, AND PREVENTION TECHNIQUES Diallo Abdoulaye Kindy and Al-Sakib Khan Pathan Department of Computer Science, International Islamic University Malaysia, Malaysia
- 6.Preventing SQL Injection Attacks in Stored Procedures Ke Wei, M. Muthuprasanna, Suraj Kothari Dept. of Electrical and Computer Engineering Iowa State University.
- 7.<https://www.acunetix.com/websitesecurity/sql-injection/>
- 8.https://link.springer.com/chapter/10.1007/978-3-540-24852-1_21
- 9.https://www.academia.edu/download/53070642/advanced_sql_injection.pdf
- 10.CERT Vulnerability Note VU#282403. <http://www.kb.cert.org/vuls/id/282403>, September 2002.
- 11.A. Acharya and M. Raje. Mapbox: Using parameterized behavior classes to confine applications. In Proceedings of the 9th USENIX Security Symposium, pages 1–17, August 2000.
- 12.Aleph One. Smashing the stack for fun and profit. Phrack, 7(49), 1996.
- 13.A. Alexandrov, P. Kmiec, and K. Schauser. Consh: A confined execution environment for internet computations, December 1998.